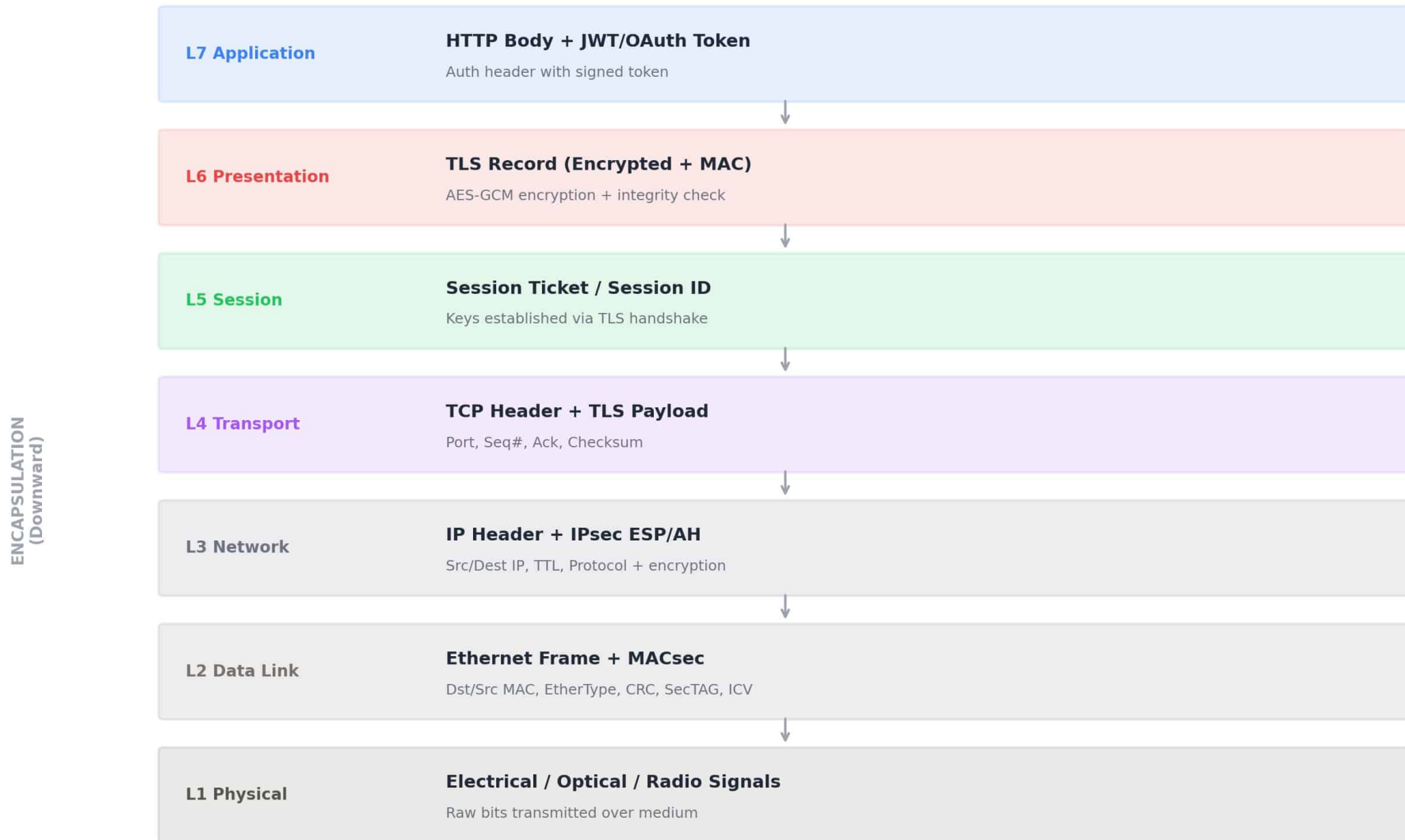


OSI 7-Layer Model — Security Overview



Packet Encapsulation with Security — Sender Side

Data travels DOWN the stack. Each layer wraps the payload with its own security headers.



Certificate Chain of Trust & PKI

Hierarchical trust: Root CA → Intermediate CA → End-Entity Certificate → Client Validation

VALIDATION STEPS

1. Receive cert
2. Check validity
3. Hostname match
4. OCSP/CRL check
5. Verify signature
6. Build chain to root
7. Trust decision

❏ ROOT CA

Self-signed • Offline • Stored in HSM • In OS/Browser Trust Store

signs

❏ INTERMEDIATE CA

Online • Handles daily issuance • If compromised, revoke without regenerating root

signs

❏ END-ENTITY CERTIFICATE

Contains: Public Key • Domain • Validity Period • Key Usage • CA Signature

validates

✔ CLIENT VALIDATION

Check expiry → Hostname match → OCSP/CRL → Verify signature → Chain to root

PKI COMPONENTS

CA (Root)

Intermediate CA

RA (Registration)

End Entity

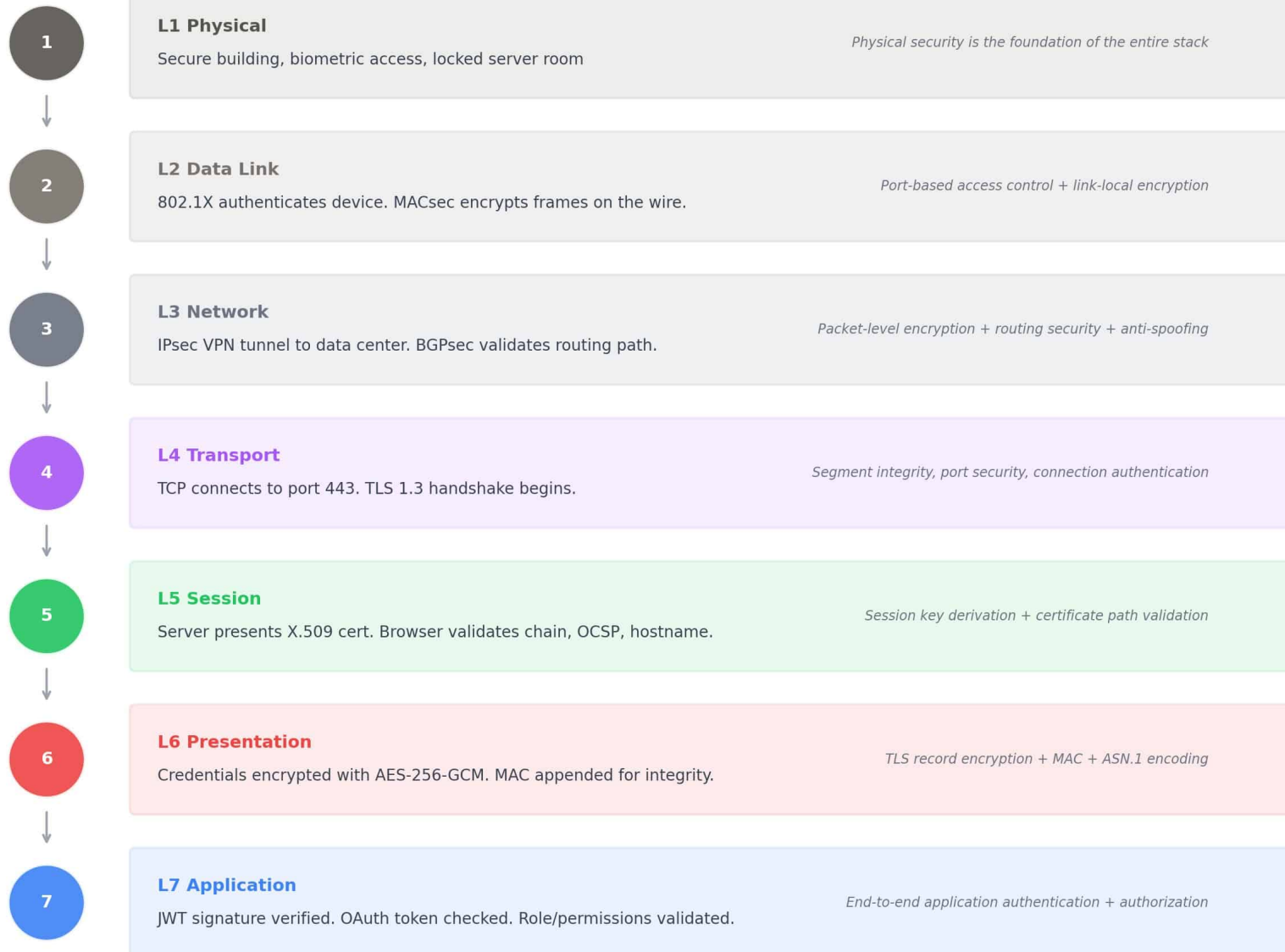
Repository/OCSP

Trust Store

HSM

Complete Secure Communication Flow — Banking Login Example

Every layer contributes. Any single failure blocks the communication at that exact layer.



DEFENSE IN DEPTH: If any layer fails (revoked cert, bad MAC, wrong CRC, expired token, physical tamper)

the communication is blocked at that exact layer. Multiple independent checks prevent single point of failure.

Authentication Mechanisms by OSI Layer

LAYER	AUTHENTICATION MECHANISM
L7 Application	Username/password, MFA, OAuth, SAML, Kerberos, API keys, JWT signature verification
L6 Presentation	X.509 certificate parsing and path validation
L5 Session	TLS handshake mutual authentication (mTLS), session token validation
L4 Transport	TLS certificate authentication (sits atop TCP)
L3 Network	IPsec PSK or certificate-based auth, RPKI for BGP route validation
L2 Data Link	802.1X EAP-TLS/PEAP port authentication, MAC address filtering
L1 Physical	Biometrics, smart cards, physical security guards, facility access control

Certificate Lifecycle: Creation & Validation

1. Key Generation CREATION (Issuer Side)

Entity generates asymmetric key pair
(RSA 2048+, ECDSA P-256, Ed25519)
Private key stored in HSM

2. CSR Creation

Certificate Signing Request:
Public key + Domain + Org info
+ Key usage flags

3. Identity Validation

DV: Domain control proof
OV: Legal existence verified
EV: Deep operational vetting

4. CA Signing

CA hashes CSR contents
Signs hash with CA private key
Digital signature embedded

5. Issuance

Certificate delivered:
Public key, Subject, Issuer,
Serial, Validity, Key usage

6. Installation

Installed on server
Presented during TLS handshake
Private key kept secure

1. Receive Certificate VALIDATION (Client Side)

Server presents cert during
TLS handshake (L5-L6)

2. Check Validity

Verify not expired
Hostname matches CN/SAN

3. Check Revocation

Query OCSP responder
Or check CRL for revoked status

4. Verify Signature

Use CA public key from
trust store to verify signature

5. Chain Building

Build chain: End-entity →
Intermediate → Root CA

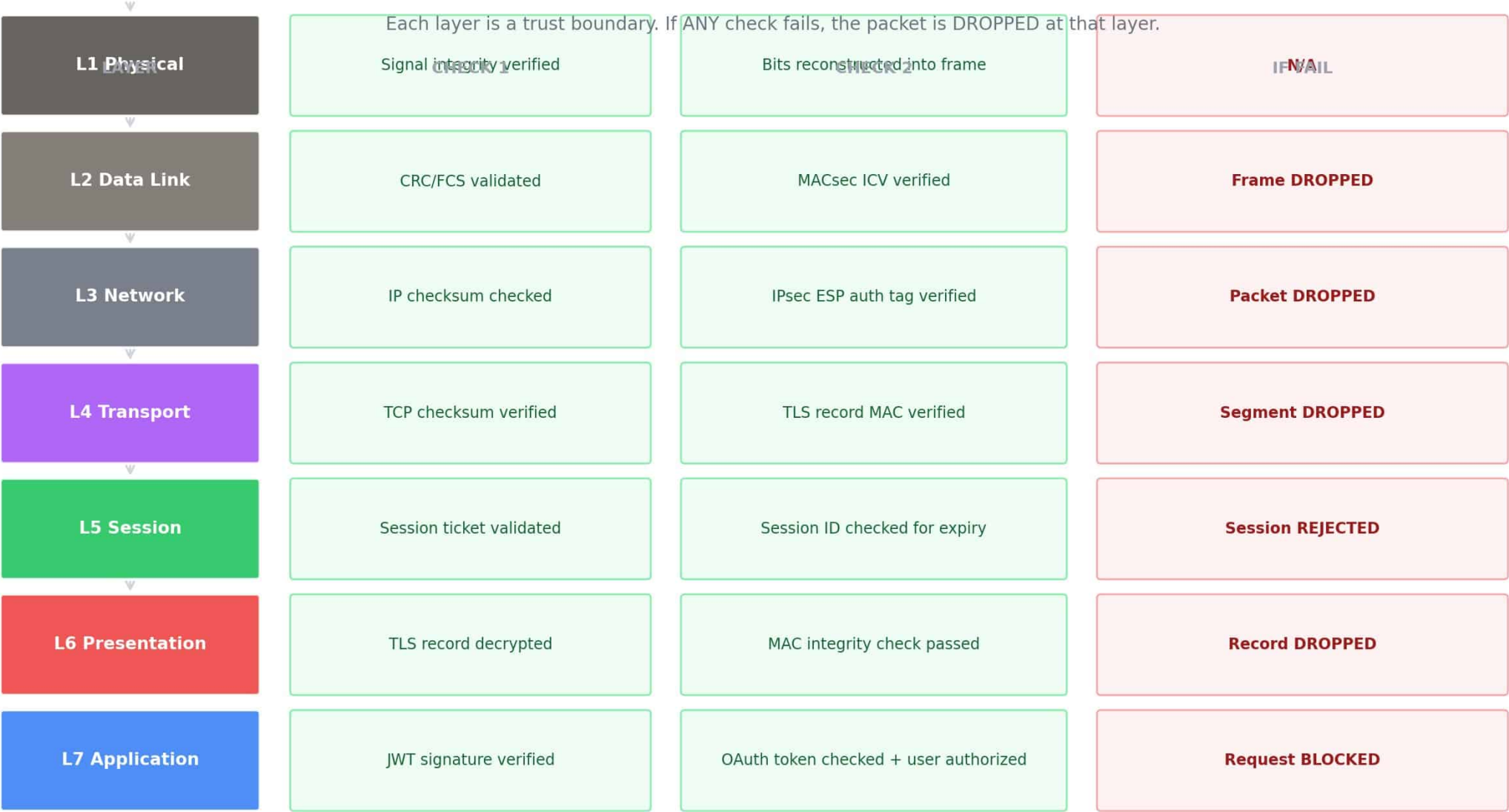
6. Trust Decision

All checks pass = TRUSTED
Any failure = WARNING/BLOCKED

↔
TLS
Handshake

PKI operates at Layers 5-7 (TLS handshake, certificate validation, JWT signing) but trust propagates through the entire stack.

Trust Decision Points: Where Packets are Verified Before Passing Up



Green = Security verification passed | Red = Packet dropped / blocked at that exact layer

Key Takeaways: OSI Security & Cryptography

1

Defense in Depth

Security is layered. Each OSI layer adds its own protection. No single layer is sufficient alone.

2

Encapsulation

Data travels down: each layer wraps security headers. Travels up: each layer verifies before passing upward.

3

Hierarchical Trust

Root CAs anchor the system. Intermediates handle issuance. End-entity certificates prove identity.

4

PKI + Private Keys

PKI binds public keys to identities. Private Key Infrastructure (HSM, enclaves) protects the secrets.

5

Authentication Everywhere

From physical biometrics (L1) to JWT validation (L7) — every layer proves identity differently.

6

Verification at Every Layer

CRC, MAC, checksums, signatures, revocation checks ensure authenticity before upward pass.

7

Fail-Safe Principle

Failure at ANY layer blocks the packet. Multiple independent checks prevent single point of failure.